

PRODUCT & RELEASE REVIEW

Codexa Bounded Causal Change Intelligence

Bounded, deterministic relationship evidence for Codexa's existing change-governance flow.

PR summary for codex/context-intelligence-next against main.

- Base: c306c1d (v0.18.0)
- Validated feature source head: 0474276; published as 869257e
- CI hardening head: 41118bb; published as 9c29408
- First review hardening head: a6ac9d0; published as 05a1dc3
- Final code head: 0133b5f
- Published code head: c780dee
- Final code tree: be815a056a19ce231b8200d6fc8e0e4a87617e8f
- Branch delta before this evidence refresh: 73 files, 6,737 insertions, 336 deletions
- Commits before this evidence refresh: 16 Conventional Commits - 6591e60 - feat: add bounded causal change intelligence - 0474276 - test: accept SDK validation wording - d18637f - docs: add context intelligence PR summary - 41118bb - fix(bootstrap): preserve first terminal condition - 3e2608a - docs: refresh context intelligence review evidence - a6ac9d0 - fix(workflow): preserve capped membership authority - 3fa989c - docs: record workflow membership review fix - balf090 - fix(workflow): retain exact capped membership - c815415 - docs: finalize context intelligence release evidence - 4862bb4 - perf(startup): attest compact index status - leecdd8 - fix(index): bind witness to serialized snapshot - 2e0c140 - fix(index): recognize typed MCP server receivers - 0a962f5 - docs: refresh final context intelligence evidence - ad86a48 - fix(parser): validate MCP receiver property provenance - 470fcc9 - fix(index): require current graph workflow lanes - 0133b5f - fix(index): cache status integrity safely

Executive Outcome

Codexa now explains a proposed or completed change through bounded, source-backed causal evidence: the declared edit target, the runtime or workflow path it participates in, nearby blast-radius evidence, and the tests that can verify it. The same evidence model follows change planning, post-edit review, committed change review, and proof without granting itself edit authority or changing a readiness verdict.

This keeps Codexa in its lane. GitNexus- and Graphify-style relationship value is delivered inside Codexa's existing local governance and completion flow; there is no graph database, graph query language, vector service, UI, new MCP tool, cross-repository crawler, or embedded model call.

The implementation uses a functional-core/imperative-shell design: immutable facts, explicit typed transitions, deterministic fingerprints, pure bounded selection, stable tie-breaking, and side effects confined to existing index and snapshot boundaries.

Highest-ROI Adjustments

1. One evidence model across the completion lifecycle

- Adds schema-validated evidence bundles to change plans, task snapshots, post-edit review, committed review, and proof cards.
- Preserves original edge direction and provenance on every chain segment.
- Separates caller-authorized edit targets from inferred read dependencies and verification targets. Evidence can explain scope; it cannot widen scope.
- Keeps evidence advisory: it cannot promote authority, readiness, or verdicts.
- Carries stable snapshot, task, chain, and bundle identities through MCP compaction, with explicit counts, gaps, and truncation receipts.

2. Framework execution surfaces become useful graph evidence

- Indexes Commander CLI roots, aliases, subcommands, singleton and namespace forms, plus CommonJS destructuring and namespace usage.
- Indexes MCP tool registrations, including bounded helper-wrapper discovery.
- Follows exact MCP receiver provenance through current-file typed options, Pick projections, destructuring, renamed bindings, and property access.
- Resolves lexical declaration identity so shadowed `program`, `Command`, `server`, and helper names cannot create false workflows.
- Rejects control-character names and unrelated look-alike receivers.
- Keeps a cold production-source contract between every derived MCP workflow and the authoritative 23-tool registry, preventing stale cache data from masking parser drift.
- Uses one-pass workflow evidence indexes and production-first bounding so test fan-out cannot evict the runtime implementation from a workflow packet.

3. Deterministic, database-free causal traversal

- Bounds a bundle to 3 chains, 6 segments per chain, depth 4, 12 paths, 4 tests, 4 gaps, 4,096 visited nodes, 16,384 examined edges, and 8 analyzed targets.
- Preserves deterministic output under edge-order permutations and diamond graphs through canonical ordering and explicit tie-breaking.
- Stores canonical adjacency references in `Uint32Array` form and materializes neighbor objects only during the bounded traversal.
- In a 500,000-edge fixture, retained adjacency fell from about 160 MiB to exactly 4,000,000 bytes (about 3.8 MiB), roughly a 40x reduction; setup stayed near 1.3 seconds. Retained references are capped at 8 bytes per edge.

4. Safe index and transport evolution

- Advances the derived index revision to 6. Earlier indexes remain readable but stale and rebuild; revision-6 indexes fail closed if graph/workflow lanes or exact workflow membership are missing or malformed. The parse-cache revision also advances so prior parser results cannot survive changed execution-surface semantics.
- Persists only the paths omitted by public workflow caps in an internal `workflowMembershipSpill` map. Every public workflow, MCP, facts, and relational projection remains unchanged and bounded.
- Uses the same 512 MiB UTF-8 limit in the writer and loader. Oversized indexes fail before atomic replacement, so the writer cannot publish an artifact the loader would reject.
- Preserves workflow truncation receipts and evidence identity through compact MCP profiles.
- Keeps existing public commands and MCP tools intact; the change enriches their evidence rather than introducing another overlapping surface.
- Publishes a manifest-v2 `index-integrity.json` witness in the same atomic index bundle. It binds exact index/freshness byte lengths, SHA-256 digests, stable file identity, the current revision, and checkout snapshot identity.
- Validates current-revision array shape and exact workflow membership before issuing the witness. The writer probes same-size rewrite observability on the actual filesystem. A proven filesystem uses metadata-only validation for an unchanged index; uncertain filesystems and changed metadata use a secure full digest. Recognized current-manifest mismatches fail closed in status and normal index loads; legacy revisions remain readable but stale.
- Updates `@modelcontextprotocol/sdk` from 1.29.0 to 1.30.0. Codexa's response budget remains at most 512 KiB, well below the SDK's 10 MiB stdio input cap. The resolved dependency audit is clean.

Human Workflow Simulation

An exact-head disposable JavaScript checkout service was exercised through the same sequence a developer uses: initialize, index, inspect, plan, edit, observe staleness, auto-refresh, test, post-edit review, proof, commit, and strict committed review. Codexa indexed 8 files, 13 symbols, 54 usage sites, 53 graph edges, zero parser errors, and both the Commander `checkout` and MCP `checkout_quote` workflows.

The saved plan explicitly authorized one implementation and one test file. A quantity-limit edit made status report stale (`dirty-files-changed`); `repo-map` then auto-refreshed to `fresh-with-dirty-overlay`. The targeted and full-suite Node test runs each passed 2/2. Post-edit review returned `continue` with complete 2/2 coverage, no scope drift, and completion

authority complete; proof was ready with zero gaps. After the Conventional Commit feat(pricing): cap checkout line quantity, strict committed review returned PASS with the saved plan matched and no concerns.

A real stdio MCP connection initialized in 506 ms, listed the exact three core tools, and completed a 127 ms search call whose code context contained both the edited implementation and new limit message. Codexa initialization also preserved pre-existing Graphify-like TOML and JSON configuration exactly while adding only its own server entry. The current tool environment does not expose a live external Graphify MCP server, so no external Graphify call is claimed.

Two adversarial index simulations also passed. Removing current graph/workflow lanes produced missing-index; a same-size, structurally valid index mutation with restored mtime also produced missing-index, and direct loading returned null. Auto-refresh restored a valid matching index/manifest pair and the current graph/workflow lanes in both cases.

Natural manifest-v2 validation with metadataFastPath=true performed zero index reads; a forced false capability performed one 73,711-byte digest read.

Verification on the Exact Source Head

Frozen validation on final code head 0133b5f (tree be815a0):

- Build, typecheck, lint, release-path, publish, privacy, and git diff --check passed.
- The canonical clean-archive npm run security:check passed in 487 seconds: 110/110 Vitest files, 1,251 passes, 1 intentional skip, and no failures. The full security log SHA-256 is d4d3f8dbc9cb0216da59734bdf7bdfad0350b9ac13954b759e38e78a33904deb.
- Claude integration: 28 command smokes and 89 hook smokes (117 total).
- Startup context gate: project kernel 2,823/3,072 bytes; 3/23 direct tools; measured reductions of 87.2% and 69.9% on the guarded surfaces.
- npm audit: 0 vulnerabilities.
- Clean public snapshot, package/plugin hygiene, and one-commit source checks passed; the installed-package smoke passed all 31 checks. The preserved 687-file package SHA-256 is ab7268ddc40d81dfc4b6821d8793c26d92e04b8a93803822e3b80f055ca2e17b.
- The broad final schema, managed-artifact, identity, SessionStart, init, recovery, and indexer sweep passed 155/155. Independent exact-diff review separately passed 42/42 focused security/identity tests and 47/47 changed fixture/SessionStart tests before reporting no remaining P0-P2 finding.

Additional release evidence:

- Eval gate: 21 scenarios, score 1, rawRgBetter=0, and zero failures. The exact-head report SHA-256 is 65f4b051da24215d60086d15706791524eed948d5b29fa4ea122ac03456da251.
- CI-scaled hot-path benchmark: all 12 release gates passed on exact final code head 0133b5f. Key p95 measurements were index 14,982 ms, SessionStart 1,079 ms, status 645 ms, repo-map 1,263 ms, explicit brief 1,604 ms, task-only brief 3,506 ms, cached hook 677 ms, MCP startup 620 ms, MCP freshness 44 ms, MCP repo-map 106 ms, and MCP task-brief 341 ms. Adoption at 5,976 ms and SessionStart missed their unscaled soft targets but passed the 1.5x CI gates. Report SHA-256: 204f77387f7ad6cbb0720fdbb4515302f0e1471b775c627d3440e2004353fd17. Its published 68 MiB index and manifest SHA-256 values are cc761634ec899106c1c70df142312338e78f67f84d123abd3e4770da96d801d7 and 002efcc9afbbbed370089e25403b69103394a973eadd56147ac38627e5f0c025d.
- The first canonical attempt correctly stopped before measurement because its clean-archive preflight rejected a dependency symlink. The rerun used copied dependencies. One exploratory repo-map sample reached 3,857 ms while the full security suite was active; after that load cleared, uncontended p95 was 1,250 ms, with status at 606 ms and explicit brief at 1,612 ms. Both facts are retained rather than silently discarded. The uncontended report SHA-256 is 2b19494e32d57d03701a66b57752ca59ac77a2a9cdac59f4852623070378d908.
- Pinned v0.12 transport comparison: all 15 gates passed; tool-list reduction 85.3%, advertisement plus discovery reduction 59.2%, startup payload reduction 56.2%, first-result reduction 75.1%, and repeated-result reduction 86.7%. The exact-head report SHA-256 is cadc5e353041d6b7a3cf3bdf1ef591d49a1035b5bffe59055a0dde5ee15abaff.
- Focused scale regression: 22/22 passed; execution-surface, MCP transport, and coexistence regressions passed.
- Fifty in-process status calls against the 68 MiB capable-filesystem index were all fresh at 19.269 ms p50, 43.876 ms p95, and 222.316 ms max. Exact focused tests prove zero digest calls on the capable path and one digest on forced fallback. Their evidence hashes are 25d264034e722128c1c130349f0d447a3ad4c6065058d01cac68d1a3568e811e and a6200d147a0f64b0ed61961ca12270527519a3298f70e6e2022f6a2b9da9dc2c.

A faithful cold and warm final-head index of Codexa contained 483 files, 5,522 symbols, 99,472 usage sites, 41,972 graph edges, and 43 workflows in 68,010,520 bytes. The 20 Commander and 23 MCP workflows exactly matched production registrations, with zero parser errors; normalized cold/warm index and facts were exactly equal at SHA-256 `cfe8324eea273ba961c28b2376722c6e2ab6c6aeeb0d9e659680aee9470c4d0` and `f6ba5304ae61da3b07e18483979a848e642e1c7d15fcbeedcbe04bf8aa699472`. The live full-profile MCP contract matched all 23 registry entries, marker symbols, and workflow titles; report SHA-256 was `41fcb5b1eedd4dfd4344592633455cf24935a8a55e408dfa4f7fe45337c7631a`. Only 2 workflows needed spill membership, for 9 spill entries (5 unique paths) and a maximum of 5 on one workflow. `workflow-path` recovered `command` index and `command` `semantic-index` from `tests/task-lifecycle.test.ts` even though that test was outside the displayed 20-test cap. `change-plan` then emitted both workflows as required checks while keeping only the caller-declared test editable.

The SDK update initially exposed one brittle assertion that accepted only the old validator wording. `0474276` widened that test to accept both stable wording forms, after which the complete security gate passed without a waiver.

The first PR run then exposed a pre-existing Windows bootstrap race: an output cap could start process-tree termination, but the still-armed stage timer could fire during slow `taskkill` teardown and relabel the earlier output-cap failure as a timeout. `41118bb` preserves the first terminal condition and makes the regression deterministic by forcing teardown across the timer boundary. The focused test passed 3/3 with typecheck, lint, release-path verification, and `git diff --check`; independent review found no P0-P2 issue. No deadline or log bound was relaxed.

Automated PR review then found that the 40-file public `relatedFiles` cap could hide a later production member from internal `change-plan`, `post-edit`, `proof`, and `required-check` matching. `a6ac9d0` keeps the public/MCP caps unchanged while matching against retained workflow steps and prioritizing every scoped member up to the public 64-file plan bound. Regressions cover production target #41 and a 21-member scope where only the former receipt omission is edited. Five focused files and 36 tests passed with typecheck, lint, and diff checks; independent re-review found no P0-P2 issue.

A fresh exact-head review then demonstrated a stricter case: tests beyond the 20-test cap could still disappear from internal matching because typed workflow steps and production-first related files were also bounded. `ba1f090` replaces that inference with exact pre-cap membership spill data, threads it through plan, workflow query, evidence, `post-edit`, `proof`, and `required-check` consumers, and adds regressions for test #21, test-symbol-only scope, and dependent tests seeded by typed `TEST_COVERS_WORKFLOW` steps. Legacy revision-2 artifacts rebuild, and the then-current revision-3 artifacts cannot load with incomplete spill data. Independent semantic review reported no P0-P3 finding.

The exact-head performance preflight then exposed a high-variance startup path: status parsed and materialized the full 67 MiB index only to report compact freshness. `4862bb4` adds the atomic integrity witness and securely hashes the index stream while parsing only bounded status metadata. On clean Node 22, `SessionStart` moved from the observed failing 1,783 ms p95 baseline to 710 ms; MCP freshness moved from an 834 ms outlier/failure to 85 ms p95. The witness does not authorize evidence queries, and malformed/torn/legacy artifacts retain the full-parser fallback. Independent integrity, identity, concurrency, and human `init-edit-refresh` review found no release-blocking regression. Final review found and closed one publication race before upload: an exported writer could validate a mutable object, yield for directory I/O, and serialize a later mutation. `1eecdd8` now captures the exact serialized index, freshness, witness, and fact membership synchronously before the first await; a regression with a deferred mutation proves the published index remains the value attested.

The final clean-cache preflight then exposed a parser/cache divergence that fixture-only testing had hidden: identical cached source at the same cache version contained 21 MCP markers, while a cold parse of the real registration module contained none. The registry authority is 23 tools. `2e0c140` follows typed options and `Pick` projections to the exact destructured MCP receiver property, rejects mixed HTTP/MCP containers and shadowed look-alikes, advances the parse-cache and index derivation revisions, and asserts the cold production marker set exactly equals the registry. Cold and warm self-index signatures now match at all fact lanes and produce all 43 execution workflows. Independent adversarial re-review found no P0-P2 issue.

The next PR review found that an unrelated nested property named `server` could still be accepted in a file that also imported the MCP SDK. `ad86a48` records exact typed property-access nodes and accepts only the MCP-typed property; mixed HTTP/MCP containers and inline look-alikes now stay out of the graph. Independent human simulation confirms `checkout_quote` is indexed while a Graphify-like `graphify_query` look-alike is not.

Two final integrity reviews then closed derivation and hot-path gaps. `470fcc9` requires current graph and workflow lanes before a bundle can load. `0133b5f` advances to revision 6 and manifest v2, capability-gates metadata validation, uses SHA-256 whenever capability or identity is uncertain, and distinguishes a current integrity mismatch from legacy absence so a valid-looking tamper cannot fall through to the generic loader. Normal current-index loads independently verify the manifest digest and snapshot. All four GitHub review threads were replied to with exact published commits and resolved.

Risk-Budgeted Review

Finding weights are critical 8, high 5, medium 3, and low 1. Merge requires no critical or high finding and no more than 4 residual points.

Independent review found and closed every release-significant finding before this evidence commit: lexical receiver shadowing, workflow membership lost to public caps, eager object-heavy adjacency retention, mutable writer input, stale parser cache, unvalidated nested MCP receiver properties, incomplete current graph/workflow lanes, and full-index status hashing plus its associated digest-mismatch fallback. Regression tests cover each fix. The final exact-diff review reports no remaining P0, P1, or P2 finding; all four actionable GitHub threads are resolved. Correctness, authority, scale, dependency, security, and human reviews therefore report 0 critical, 0 high, and 0 medium findings.

Residual score: **3/10 (within budget)**. Low-risk watch items are the one-time $O(E \log E)$ canonical typed-array sort used to build a deterministic adjacency index, pathological repetition of large hidden workflow memberships, and unusual remote-filesystem metadata coherency. Hidden membership is byte-bounded and rejected before publication; traversal and retained adjacency storage remain explicitly bounded. Metadata caching is capability-gated and automatically falls back to content hashing rather than accepting an unproven shortcut.

Scope Honesty

- New language or framework support: Commander and MCP execution-surface recognition inside existing JavaScript/TypeScript indexing; no new language.
- Embedded LLM call: no.
- Public surface: existing CLI/MCP responses gain bounded evidence; no new MCP tool or configuration knob.
- Dependency change: no new direct dependency; existing MCP SDK updated to 1.30.0 with audited transitive resolutions.
- Linked issue: none; this is an owner-directed enhancement phase.

Rollout, Deployment, and Live Verification

- 1. Require all six exact-head GitHub jobs: check, package-smoke, benchmark, and worktree-bootstrap on Ubuntu, macOS, and Windows.
- 2. Resolve every actionable review thread and keep the final residual score at or below 4 before merge.
- 3. Merge the feature PR through the protected main branch.
- 4. Use only `.github/workflows/release-please.yml` on main with `secrets.RELEASE_PLEASE_TOKEN` to create or update the expected `chore(main): release 0.19.0` PR.
- 5. Inspect and merge that checked release PR. Let the resulting GitHub Release trigger `.github/workflows/npm-publish.yml` with `secrets.NPM_TOKEN`.
- 6. Verify the GitHub release/tag, npm registry version, MCP Registry entry, fresh install, CLI version/startup, and a real MCP initialization/tool call.

No manual tag or direct npm publish is part of this rollout.

Rollback

Before publication, revert the feature commits and rebuild derived indexes under the restored code version. After publication, preserve npm immutability: revert on main, ship a corrective patch through the same secret-backed flow, and deprecate the affected version only for a material safety risk.